



# AI Aegis (灵盾)

面向 AI Agent 的实时执行前安全防护与安全运营平台

Real-time, deterministic pre-execution guardrail & security-operations plane for autonomous agents

团队 **Goodevenin9 团队** 总负责人 **万翔浩** 副负责人 **李香颐** 指导老师 **韩东岐 老师** 版本 **v1.0.3**

## LLM 提取证据 · 代码负责裁决

热路径 0 次大模型调用；同输入可复现；只升不放

确定性 状态机裁决

封闭契约 布尔/枚举

跨轮次 会话级

不可绕过 Manifest

### Boundary

归一化 · 越狱 · 高危 Shell · 敏感路径

### Capability

工具名映射 → 会话能力清单集合匹配

### Radius

路径 / URL / MCP → 影响范围分类

### Drift

固定权重状态机累积会话风险

### Friction

确定性决策表 · 唯一裁决点

### 问题 · Agent 攻击面

- **直接提示注入** — 指令覆盖 / 系统提示提取
- **间接与工具结果注入** — 恶意指令藏在 MCP 返回值
- **权限试探与升级** — 跨轮次逐步索取更高权限
- **数据外泄** — 敏感读取 → 外部写入序列
- **不可逆破坏** — 删除 / 发布 / 强推 / 删凭据
- **供应链投毒** — 被污染的 Skill / MCP 工具

### 核心创新

- ① **证据/裁决分离** — 模型只给布尔/枚举，分数与裁决由代码定
- ② **会话级五段管线** — 从单轮升级到跨轮状态机
- ③ **三重正交防线** — 规则 + 离线 ML + 会话状态
- ④ **不可绕过 Manifest** — 插件自报不能放宽
- ⑤ **只升不放** — 只能升级拒绝，绝不静默放宽
- ⑥ **受治理免疫学习** — 人工激活 · 贡献封顶 · 不能独立阻断
- ⑦ **统一哈希链审计** — 自动判定与人工操作同链

### 评测结果 (机器报告可复现)

| 数据集 (n)           | Judge 检出/误报   | 五段 检出/误报             |
|-------------------|---------------|----------------------|
| InjecAgent (1071) | 96.6% / 0%    | <b>97.0% / 0%</b>    |
| AgentHarm (352)   | 89.2% / 17.1% | <b>89.2% / 16.5%</b> |
| AgentHarm + 复核    | —             | <b>90.3% / 16.5%</b> |

离线 PreTool 网关重放 · 付费调用 1,432 次 · 0 失败 · \$0.196

### 现有方案 · 四类不足

- **单轮视角**：看不见跨轮试探与主题偏移
- **裁决不可复现**：交给 LLM 判官，无法回归与定责
- **事后而非事前**：告警时副作用已发生
- **运营与防护割裂**：缺少统一证据链

### 五段证据契约 (封闭)

```
{"theme_shifted": false, "permission_probing": false,
"request_escalation": false, "explicit_harm": false,
"requested_capabilities": ["file_read"],
"requested_radius": "project"}
```

多余字段 / 未知枚举 / 非布尔 → 整包拒绝

### 免疫学习 · 生命周期

① Candidate · 从已确认会话学习

② Shadow · 记录但 **不影响判定**

③ Active · **人工批准后** 方可影响 Drift

④ Decaying → Retired · 衰减与归档

### 系统架构 · 四层

- **接入层** — 原生 Hook / 插件 / 代理 / 框架 SDK / MCP
- **本地引擎** — 规则 + Guardian ML + 五段管线 + 治理
- **审计存储** — SQLite + SHA-256 哈希链
- **运营平面** — LangGraph · RAG · 记忆 · 免疫 · 审批

### 关键技术指标

5

段裁决管线

108

检测规则

217

REST 端点

1,555

基准响应

73k+

行 Python

1,090+

测试通过

### 差异化

- 正交于「LLM 判官」的**确定性裁决**
- 覆盖 Claude Code / Codex / Copilot CLI / Cursor / OpenClaw
- 框架 SDK: LangChain / LangGraph / CrewAI / Hermes
- 防护 + 运营 + 治理**共用一条审计链**

### 集成与部署

- **一键安装** — pip install ai-aegis[app]
- **容器** — 4 份 Compose (demo / agent / self-host / nginx)
- **插件** — Claude Code · Codex · Copilot CLI · Cursor · OpenClaw
- **SIEM** — Splunk / Datadog / Sentinel / QRadar / Chronicle / OTLP

### 治理控制面

工具权限与频率限制 · JIT 即时授权 · Egress 出站治理 · 成本预算 · 设备与云策略同步 · 受治理长期记忆 · 证据 RAG (Recall@k / MRR)

### 诚实边界 (主动声明)

外部基准为离线回放，非原生 ASR；five\_stage\_semantic 为上界；AgentHarm 优化为同分片探索性；哈希链仅事后篡改可发现，不防内存攻击。

### 统一事件链 · 跨运行时—审计

before\_prompt\_build → llm\_input → llm\_output → before\_tool\_call → after\_tool\_call

Claude Code · Codex · Copilot CLI · Cursor · OpenClaw · LangChain / LangGraph / CrewAI / Hermes 收敛到同一判定语义与同一条 SHA-256 哈希链 (带 traceld 串联)。

### 评测可复现

```
python scripts/run_external_benchmarks.py \
--benchmarks injecagent agentharm --output-dir <dir>
python scripts/run_live_integration.py # 插件 → hook → API → 审计
```